Prouver qui l'on est

Identification, authentification et mots de passe

Séquence
SQ04

Partie
P01P02

Niveau
BTS SIO 1re année

Objectifs

- **Distinguer** identification, authentification et autorisation.
- **Estimer** la force d'un mot de passe, et repérer ce que le calcul ne voit pas.
- **Expliquer** pourquoi on ne réutilise jamais un mot de passe.

Prérequis : les besoins DICP et l'usurpation d'identité, vus en début d'année.

Ce matin, chez Soft-Tech

À 3 h 12, quelqu'un s'est connecté à l'outil de facturation avec le compte de Léa, technicienne. Le mot de passe était **correct**. Léa assure qu'elle dormait.

Question	Ce qu'on va comprendre
Le site s'est-il trompé ?	Ce qu'il vérifie vraiment
Comment connaître ce mot de passe ?	Deviner, ou le récupérer ailleurs
Qu'aurait-il fallu faire ?	Les bons usages, et les outils

Trois étapes qu'on confond

	Identification	Authentification	Autorisation
Question	Qui dites-vous être ?	Pouvez-vous le prouver ?	Avez-vous le droit ?
Exemple	`lea.martin@soft-tech.fr`	Le mot de passe	Créer une facture : oui
Secret ?	Non, souvent public	**Oui**	Décidé par l'organisation

Le site vérifie un secret, pas une personne. Celui qui connaît le secret devient Léa.

Trois façons de prouver

Facteur	Exemples	Point faible
Ce que je sais	Mot de passe, code PIN	Se devine, se vole, se réutilise
Ce que je possède	Téléphone, clé de sécurité, carte	Se perd, se vole
Ce que je suis	Empreinte digitale, visage	Ne se change pas s'il fuit

MFA (authentification multifacteur) : deux facteurs de familles **différentes**. Deux mots de passe, ce n'est pas de la MFA.

Des secrets partout dans un SI

Secret	Qui s'en sert	S'il fuit
Mot de passe	Une personne	Usurpation de son compte
Clé d'API	Un programme	Le service est utilisé à vos frais
Jeton de session	Le navigateur, après connexion	Connexion volée sans mot de passe
Code PIN	Une personne, sur un appareil	Accès à l'appareil

Même règle pour tous : **ne se partage pas, ne s'écrit pas en clair, se change dès qu'il a fui.**

Deviner un mot de passe

	Force brute	Attaque par dictionnaire
Principe	Essayer **toutes** les combinaisons	Essayer les mots de passe **probables**
Liste utilisée	`aaaa`, `aaab`, `aaac` …	Mots courants, fuites passées, variantes
Efficace contre	Les mots de passe courts	Les mots de passe « humains »

Sur une page de connexion qui bloque après cinq essais, seul le dictionnaire a une chance : **les cinq premiers mots de sa liste.**

L’entropie : mesurer le hasard

Nombre de combinaisons = N^L, avec **N** caractères possibles et une longueur **L**. On l’exprime en bits : **entropie = L × $\log_2$(N)**.

Caractères utilisés	N	Bits par caractère
Chiffres	10	3,3
Minuscules	26	4,7
Minuscules et majuscules	52	5,7
Lettres et chiffres	62	6,0
Tout le clavier	95	6,6

Chaque bit en plus **double** le nombre d’essais nécessaires.

Calculons

Hypothèse : un attaquant équipé teste **un milliard** de combinaisons par seconde.

Mot de passe tiré au hasard	Calcul	Entropie	Tout essayer
Code de 4 chiffres	4 × 3,3	13 bits	Instantané
8 caractères, tout le clavier	8 × 6,6	53 bits	Environ 77 jours
12 minuscules	12 × 4,7	56 bits	Environ 3 ans
14 caractères, lettres et chiffres	14 × 6,0	83 bits	Des centaines de millions d'années

La longueur pèse plus que la complexité. Au-delà de 80 bits, la force brute devient irréaliste.

ATTENTION

Le calcul ne voit pas le dictionnaire

Mot de passe	Selon la formule	En réalité
`azerty`	28 bits	Dans toutes les listes, trouvé au premier essai
`P@ssw0rd!`	59 bits	Variante connue, trouvée en quelques secondes
`Mistral2019!`	79 bits	Mot + année + `!` : le schéma le plus courant

L'entropie ne mesure que le **hasard réel**. Un mot de passe choisi par un humain en a beaucoup moins que la formule ne le dit.

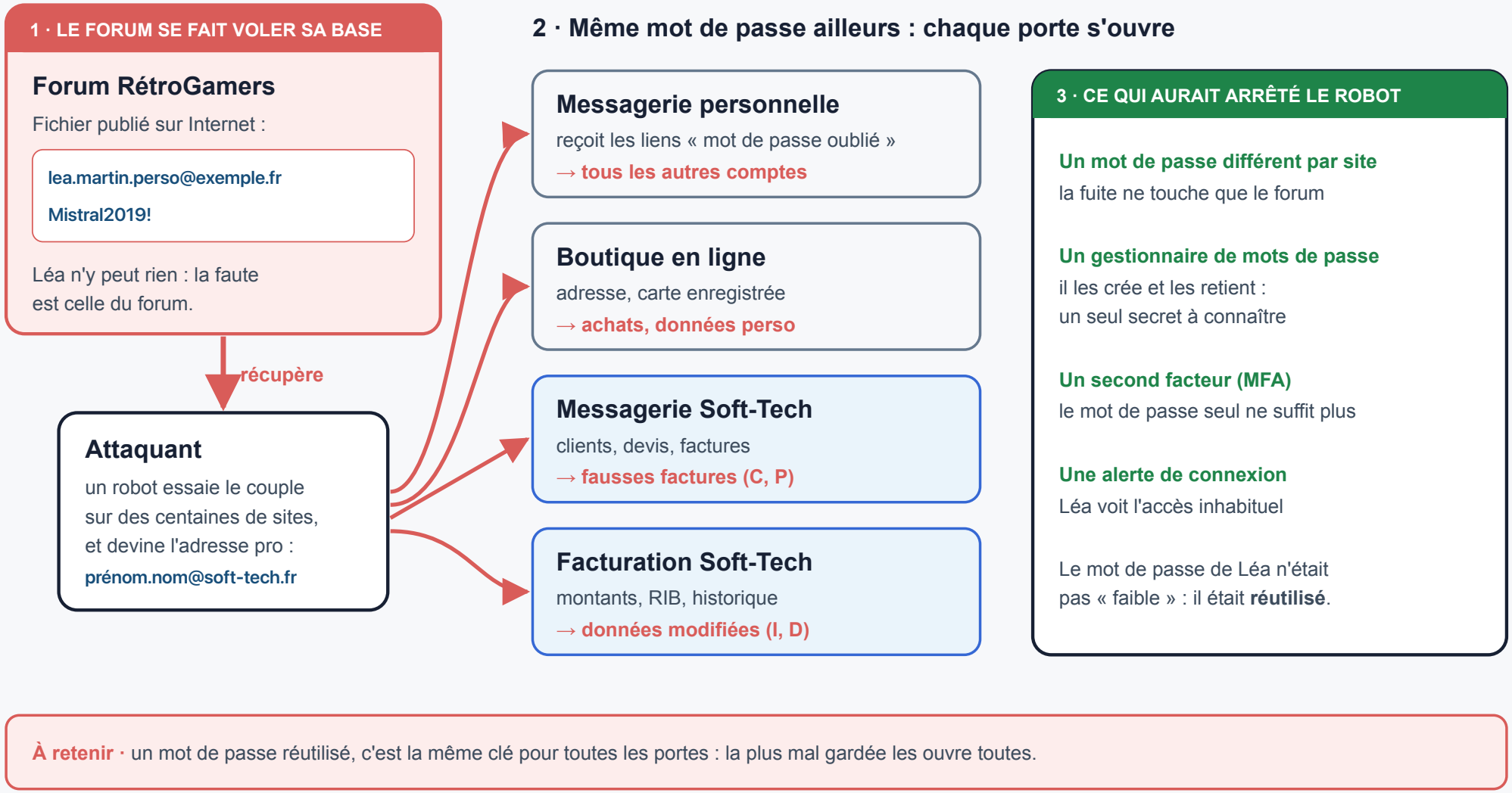
La phrase de passe

Cinq mots **tirés au hasard** dans une liste de 7 776 mots : $7\,776^5$ combinaisons, soit **65 bits**, et ça se retient.

	Exemple, à ne pas réutiliser	**Pourquoi**
Oui	`tulipe-orbite-glacier-banjo-sept`	Mots sans lien, tirés au dé ou par un outil
Non	`Le petit chat est mort`	Citation connue : elle est dans les dictionnaires

On compte l'entropie **par mot**, pas par lettre : l'attaquant connaît la liste.

Une fuite, toutes les portes



À retenir · un mot de passe réutilisé, c'est la même clé pour toutes les portes : la plus mal gardée les ouvre toutes.

ACTIVITÉ

Vérification individuelle

Sur papier · seul · 5 minutes

À produire : quatre réponses courtes, corrigées ensemble.

1. Classez : saisir son adresse, taper son code reçu par SMS, accéder au dossier RH.
2. Mot de passe de 10 minuscules tirées au hasard : son entropie ?
3. Pourquoi `Soleil2026!` est-il faible malgré ses 11 caractères ?
4. Un mot de passe de 90 bits utilisé sur trois sites est-il sûr ? Justifiez.

À RETENIR

À retenir

Notion	En une phrase
Authentification	Prouver avec un secret, que le site vérifie à la place de la personne
Entropie	$L \times \log_2(N)$: la longueur compte plus que les symboles
Dictionnaire	Un mot de passe humain est bien plus faible que son calcul
Réutilisation	Le site le plus mal protégé ouvre tous les autres

En demi-groupe : le cas de Léa en détail, et le gestionnaire de mots de passe.